

PHISHING AWARENESS

TRAINING MODULE

Recognizing, Resisting, and Reporting Phishing Attacks

Prepared by: Cyber Crazy — Security Awareness Series

By Hemil | Cyber Security Enthusiast

July 2026

Table of Contents

1. Introduction 3

2. What Is Phishing? 3

3. How to Recognize Phishing Emails..... 3

4. Identifying Fake / Spoofed Websites 4

5. Social Engineering Tactics Used by Attackers 5

6. Best Practices to Avoid Falling Victim 5

7. Real-World Examples 7

8. Interactive Quiz 8

9. Key Takeaways 9

1. Introduction

Phishing is a form of social engineering attack in which cybercriminals impersonate trusted entities to trick individuals into revealing sensitive information, such as passwords, credit card numbers, or company credentials, or into installing malware. It remains one of the most common and successful attack vectors because it targets human psychology rather than technical vulnerabilities.

This training module is designed to help employees, students, and general users understand how phishing attacks work, recognize the warning signs, and respond appropriately to protect themselves and their organizations.

Why This Matters

- Over 90% of successful cyberattacks begin with a phishing email.
- A single click can compromise an entire organization's network.
- Attackers constantly evolve their tactics, making ongoing awareness essential.

2. What Is Phishing?

Phishing is a cyberattack that uses disguised communication — typically email, but also SMS, phone calls, or social media messages — to deceive victims into taking a harmful action. The term is a play on 'fishing': attackers cast bait and wait for victims to bite.

2.1 Common Types of Phishing

- **Email Phishing** — Mass emails impersonating banks, vendors, or services, urging urgent action.
- **Spear Phishing** — Highly targeted attacks aimed at a specific individual, using personal details.
- **Whaling** — Spear phishing aimed at senior executives or high-value targets.
- **Smishing** — Phishing conducted via SMS/text messages.
- **Vishing** — Voice phishing conducted over phone calls, often impersonating IT support or banks.
- **Clone Phishing** — A legitimate previously delivered email is copied and resent with malicious links.
- **Business Email Compromise (BEC)** — Impersonating executives or vendors to authorize fraudulent payments.

3. How to Recognize Phishing Emails

Most phishing emails share common characteristics. Training users to spot these signs is the first line of defense.

3.1 Sender & Header Red Flags

- Sender address doesn't match the organization it claims to represent (e.g., support@paypa1-secure.com).
- Display name looks legitimate, but the actual email address is suspicious when you hover/inspect it.
- Reply-to address differs from the sender address.
- Email arrives from an unexpected or unusual time zone/region.

3.2 Content Red Flags

- Urgency and pressure — 'Your account will be suspended in 24 hours.'
- Generic greetings — 'Dear Customer' instead of your actual name.
- Spelling and grammar mistakes, awkward phrasing, or inconsistent formatting.
- Requests for sensitive information — passwords, OTPs, card numbers (legitimate companies never ask this via email).
- Unexpected attachments, especially .exe, .zip, .scr, or macro-enabled Office files.
- Mismatched branding — low-resolution logos, wrong fonts, or outdated company details.

3.3 Link Red Flags

- Hover over links before clicking — the displayed text may not match the actual URL destination.
- Misspelled domains (e.g., micros0ft.com, arnaz0n.in) or unusual subdomains.
- URL shorteners (bit.ly, tinyurl) hiding the real destination.
- HTTP instead of HTTPS on a page requesting login credentials.

Quick Check: Before You Click

- Hover, don't click — verify the actual destination URL.
- Check the sender's full email address, not just the display name.
- Ask: 'Was I expecting this email?' If unsure, verify independently.
- When in doubt, contact the organization directly using a known number or website.

4. Identifying Fake / Spoofed Websites

Phishing emails often lead to fake websites designed to look identical to legitimate login pages in order to harvest credentials. Recognizing a spoofed website is just as important as spotting a phishing email.

4.1 Warning Signs of a Fake Website

- URL doesn't match the legitimate domain (check spelling carefully, character by character).
- No padlock icon / invalid or missing HTTPS certificate.
- Pop-ups demanding urgent login or immediate payment.

- Poor design quality — broken images, inconsistent fonts, low-quality logos.
- Excessive permission requests or forced software downloads.
- Login forms on pages that shouldn't need authentication.

4.2 Verification Techniques

1. Manually type the organization's URL instead of clicking email links.
2. Check the certificate details by clicking the padlock icon in the browser address bar.
3. Use tools like WHOIS lookup or VirusTotal to check domain reputation and age.
4. Bookmark frequently used, verified sites (banking, email, work portals) and use only those bookmarks.

5. Social Engineering Tactics Used by Attackers

Phishing is a subset of social engineering — the psychological manipulation of people into performing actions or divulging confidential information. Understanding these tactics helps users recognize manipulation regardless of the delivery channel.

5.1 Common Psychological Triggers

- **Authority** — Impersonating a boss, IT admin, government body, or bank to demand compliance.
- **Urgency & Fear** — Creating a false deadline or threat ('account suspended', 'legal action') to bypass careful thinking.
- **Curiosity** — Enticing subject lines like 'Your parcel could not be delivered' or 'You've won a prize.'
- **Trust & Familiarity** — Impersonating a colleague, friend, or known vendor using compromised accounts.
- **Reciprocity** — Offering something 'free' to lower the target's guard before asking for information.
- **Scarcity** — 'Only 2 hours left to claim your reward' to force rushed decisions.

5.2 Related Social Engineering Techniques

- **Pretexting** — Inventing a fabricated scenario to extract information (e.g., posing as IT support asking for a password reset).
- **Baiting** — Leaving infected USB drives or offering free downloads to lure victims.
- **Tailgating/Piggybacking** — Following an authorized person into a restricted physical area.
- **Quid Pro Quo** — Offering a service or fix in exchange for credentials or access.

6. Best Practices to Avoid Falling Victim

6.1 For Individuals

- Pause before acting — legitimate organizations rarely demand instant action.
- Verify requests through a second channel (call using an official number, not one in the email).
- Never share passwords, OTPs, or PINs — no legitimate entity will ask for these.
- Enable Multi-Factor Authentication (MFA) on all important accounts.
- Keep browsers, antivirus, and operating systems updated.
- Use a password manager to avoid reusing credentials across sites.
- Regularly check bank and account statements for unauthorized activity.

6.2 For Organizations

- Conduct regular phishing simulation exercises and security awareness training.
- Deploy email filtering, DMARC/SPF/DKIM, and anti-phishing gateways.
- Establish a clear, easy process for employees to report suspicious emails.
- Apply the principle of least privilege to limit damage from compromised accounts.
- Maintain an incident response plan specifically for phishing/credential-compromise events.

If You Suspect a Phishing Attempt

- Do not click links or open attachments.
- Do not reply to the sender.
- Report it to your IT/Security team or use the 'Report Phishing' button.
- If credentials were entered, change the password immediately and enable MFA.

7. Real-World Examples

The following well-known incidents illustrate how phishing and social engineering succeed even against large, security-conscious organizations.

Scenario	How It Worked	Red Flag
Google & Facebook (2013–2015)	Attacker sent fake invoices impersonating a legitimate hardware vendor, tricking finance staff into wiring over \$100 million combined.	No independent verification of payment change requests.
Twitter Bitcoin Scam (2020)	Attackers used vishing to socially engineer Twitter employees into granting access to internal admin tools, then hijacked high-profile accounts.	Employees trusted a caller claiming to be internal IT support.
Target Data Breach (2013)	Attackers phished a third-party HVAC vendor with network access, then pivoted into Target's payment systems.	Weak vendor access segmentation and unverified email attachment.
RSA SecurID Breach (2011)	Employees received a spear-phishing email titled '2011 Recruitment Plan' with a malicious Excel attachment exploiting a Flash vulnerability.	Curiosity-driven click on an unexpected but plausible attachment.

8. Interactive Quiz

Test your understanding with the following scenario-based questions. Cover the answers and try to answer each one before checking.

Q1. You receive an email from 'IT-Support@yourcompany-helpdesk.com' asking you to verify your password immediately or lose account access. What should you do?

- A) Reply with your password since it's from IT support
- B) Click the link and reset your password right away
- C) Check the sender domain carefully and report it to the real IT team
- D) Forward it to a coworker for a second opinion

Answer: C — The domain doesn't match the company's real domain, and urgency plus a password request are classic phishing indicators.

Q2. A website you're about to log into has 'https://amaz0n-orders.com' in the address bar. What's wrong?

- A) Nothing, HTTPS means it's safe
- B) The domain is misspelled/spoofed and not the real Amazon domain
- C) The site is just using a mobile version
- D) It's a temporary URL used during sales

Answer: B — HTTPS only encrypts the connection; it does not verify the site is legitimate. The domain itself is spoofed.

Q3. Your 'CEO' emails you urgently requesting a wire transfer to a new vendor account, marked 'Confidential — handle personally.' What tactic is this?

- A) Baiting
- B) Business Email Compromise (BEC) using authority and urgency
- C) Tailgating
- D) A routine finance request

Answer: B — This is a classic BEC/whaling attempt combining impersonated authority with urgency and secrecy to bypass verification.

Q4. You find a USB drive labeled 'Salary Report 2026' in the office parking lot. What should you do?

- A) Plug it in out of curiosity to see what's on it
- B) Give it to a colleague to check first
- C) Hand it to IT/Security without plugging it in anywhere
- D) Take it home to check on a personal computer

Answer: C — This is a classic baiting attack. Never plug in unknown removable media; report it to security.

Q5. Which of the following is the SAFEST way to verify a suspicious request claiming to be from your bank?

- A) Click the link in the message and log in to check
- B) Reply to the message asking if it's genuine
- C) Call the bank using the number printed on your card or official website
- D) Trust it if the logo looks correct

Answer: C — Always verify through an independent, trusted channel — never through contact details provided in the suspicious message itself.

9. Key Takeaways

- Phishing exploits human trust and urgency more than technical flaws — awareness is the strongest defense.
- Always verify sender addresses, hover over links, and check for HTTPS and correct domains.
- Social engineering relies on authority, urgency, curiosity, and trust — pause before reacting to any of these triggers.
- Use MFA, strong unique passwords, and report suspicious messages instead of ignoring or deleting them.
- Regular training and simulated phishing exercises significantly reduce successful attacks over time.

End of Training Module